Cardinal - SQL Injection Attack - Dynamic Keyword Construction
Made by: Saif Badwan

Methodology: The same payload was tested against every combination of three independent defenses which are the WAF, RASP, and the server side input filter to determine which layer actually catches the attack, and in what order they're checked.

The payload for Dynamic Keyword Constrcution Disguised
zzz%' UNUNIONION SELSELECTECT 1,username,3,4,5,6,7 FROM users WHERE username LIKE '

Results:
This disguised payload only succeeds when the denylist filter is active, since the filter's own stripping process is what reconstructs the real keywords so with the filter off, the payload is just garbled text, with the WAF on, it gets blocked regardless.

Switches:

Layer	On	Off
WAF	Port 8080	Port 8081
RASP	&rasp= param	no &rasp=block
Filter	&serversan=param	no &serversan=denylist

Results

Test	WAF	RASP	FILTER	Results	Notes
1	Off	Off	Off	Crashed	database can't understand
2	Off	On	Off	Crashed	database can't understand
3	Off	Off	On	Succeeded	
4	Off	On	On	Succeeded	
5	On	Off	Off	Blocked	Blocked by WAF
6	On	On	Off	Blocked	Blocked by WAF
7	On	Off	On	Blocked	Blocked by WAF
8	On	On	On	Blocked	Blocked by WAF

Test 1 Screenshot:



Internal Server Error

The server encountered an internal error and was unable to complete your request. Either the server is overloaded or there is an error in the application.

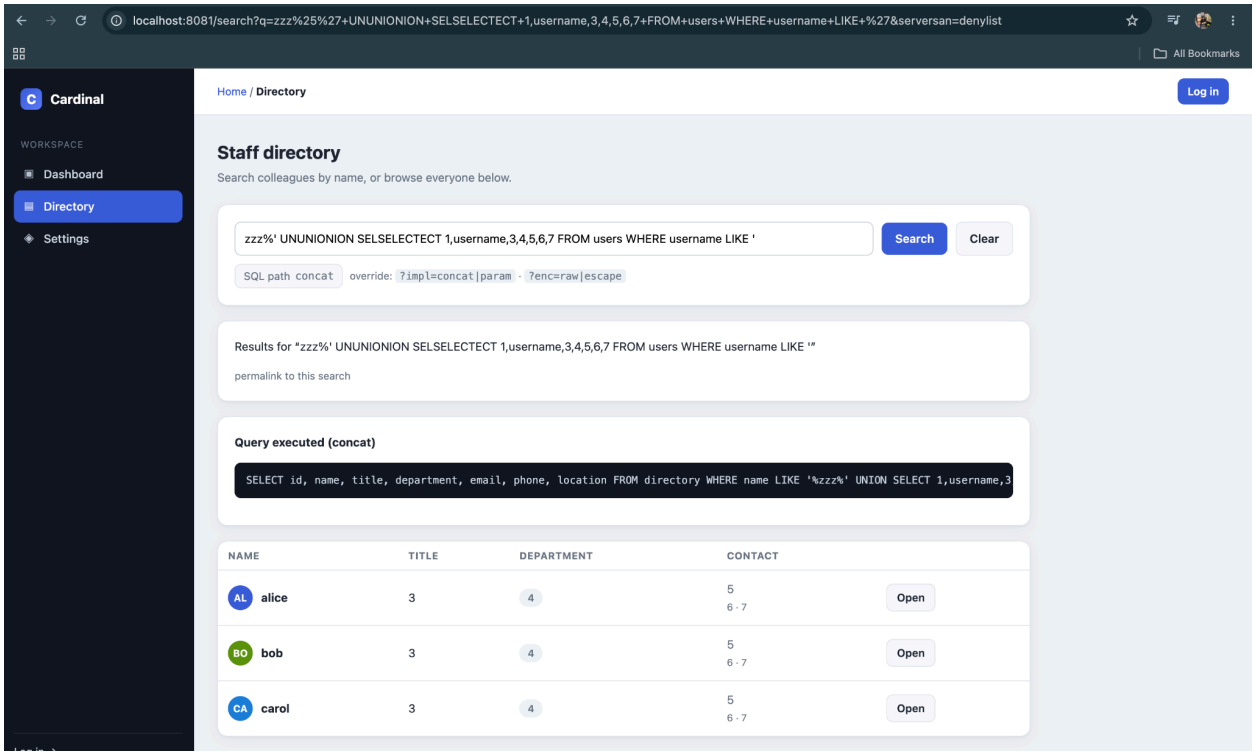
Test 2 Screenshot:



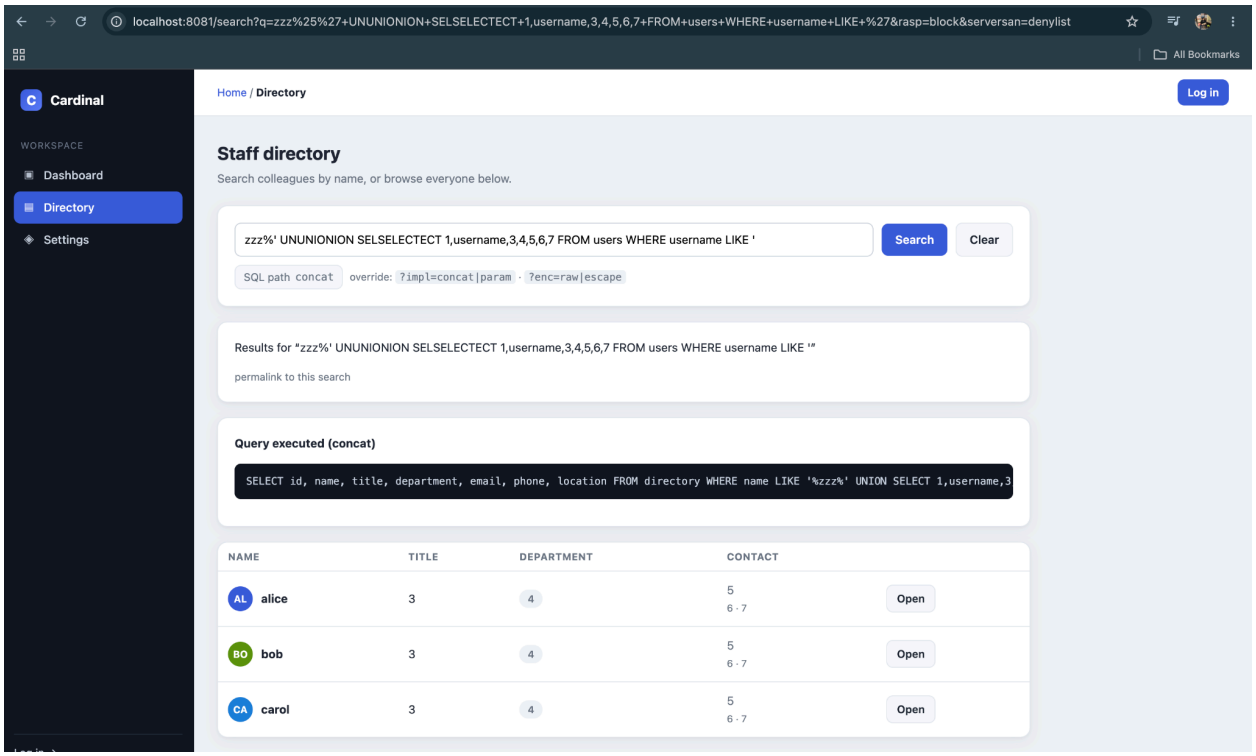
Internal Server Error

The server encountered an internal error and was unable to complete your request. Either the server is overloaded or there is an error in the application.

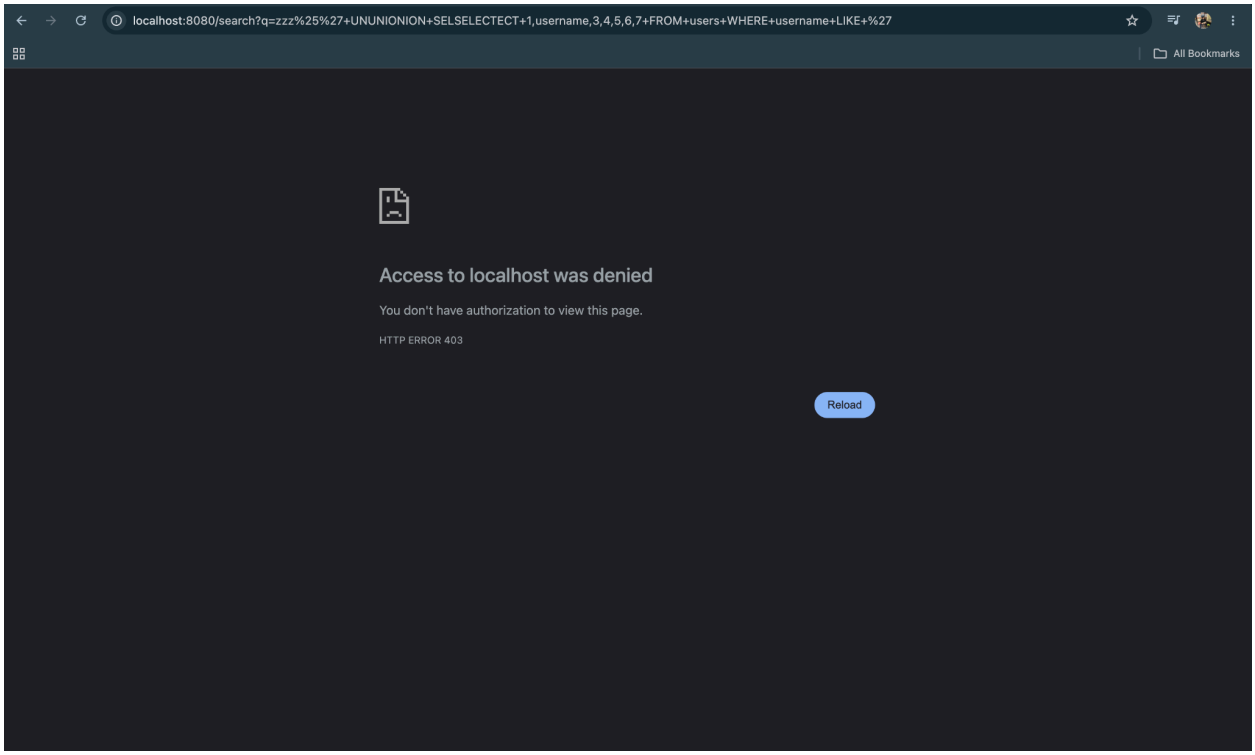
Test 3 Screenshot:



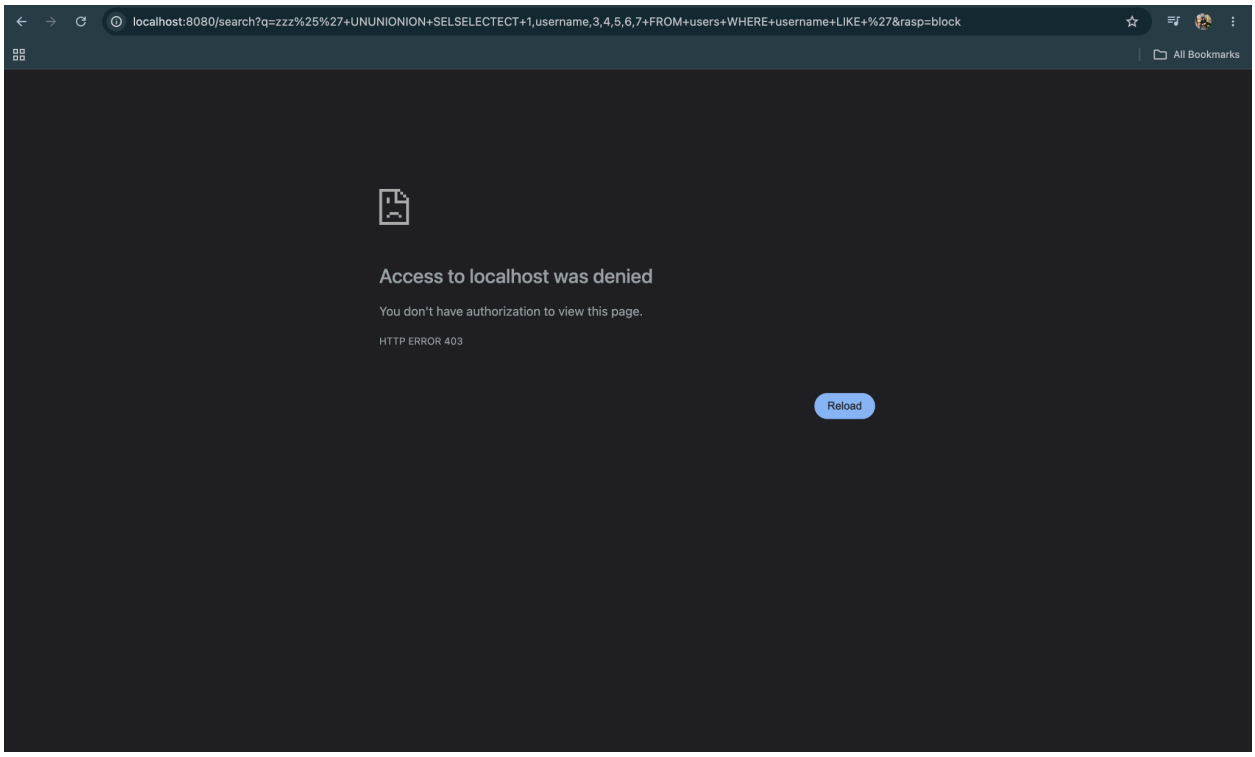
Test 4 Screenshot:



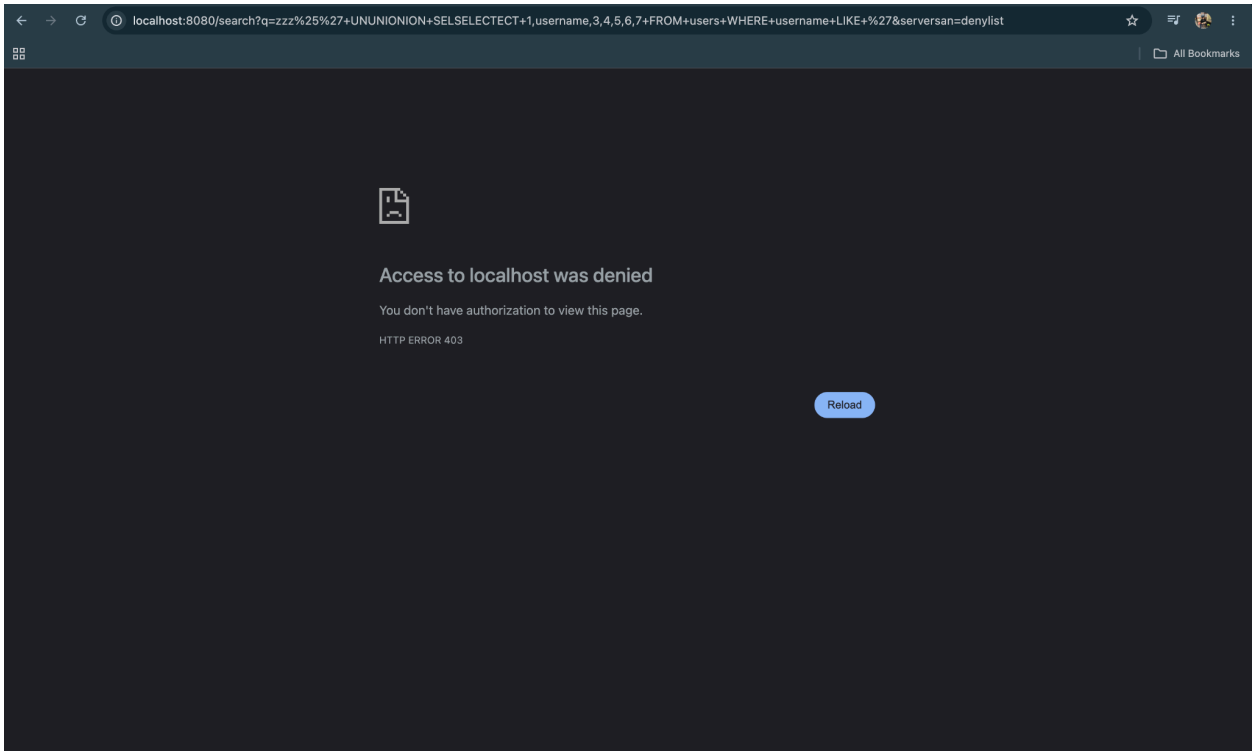
Test 5 Screenshot:



Test 6 Screenshot:



Test 7 Screenshot:



Test 8 Screenshot:

